

Client Side Vulnerabilities

Dr. Ramokapane



Phishing

Manipulated links

Delivered via email, SMS or clickable in other websites

Misspelled URLs

`https://myonlinebank.net/transaction?to=bob&value=50`

`https://myonlinebank.et/transaction?to=attacker&value=50`

Phishing

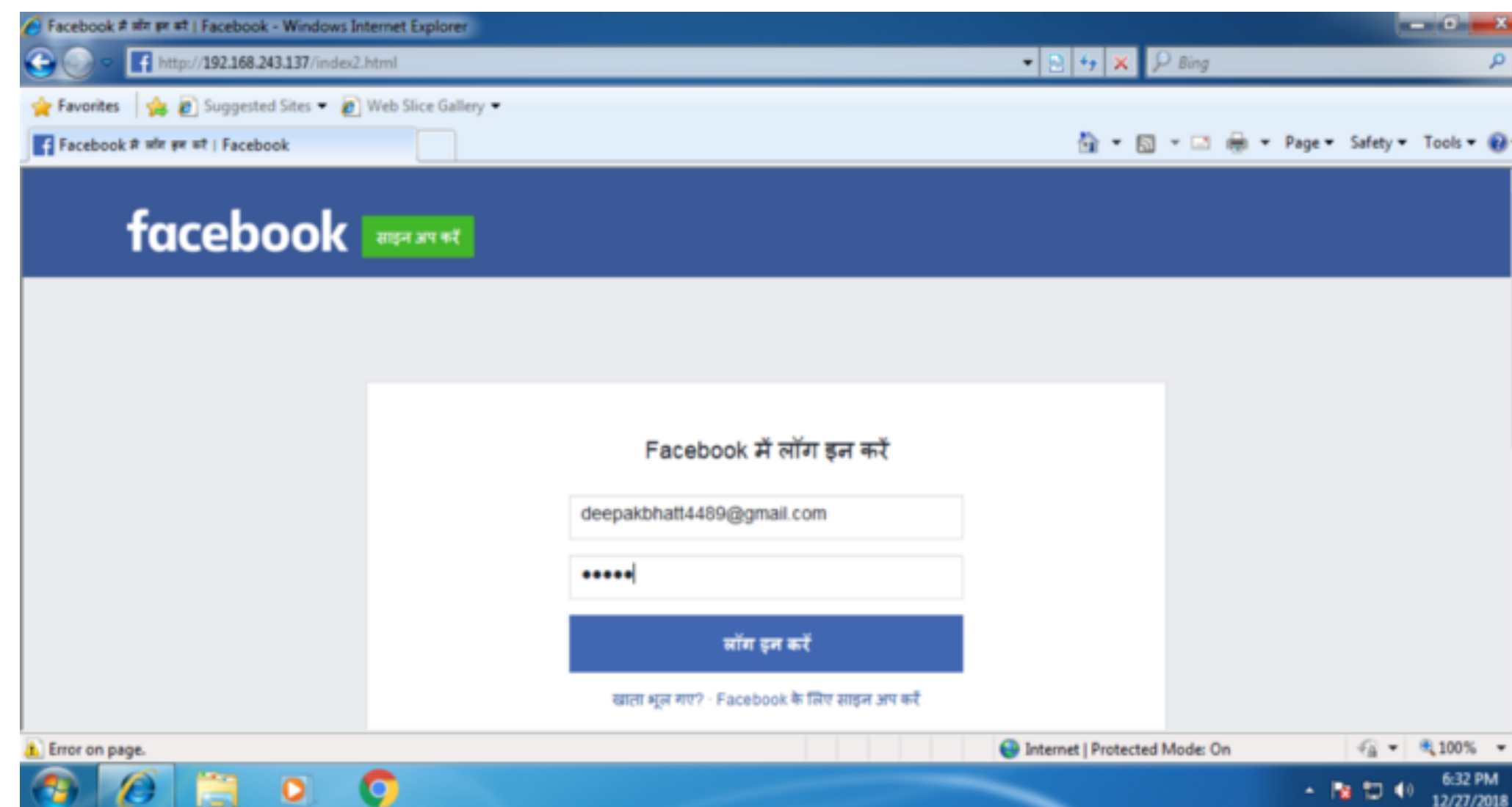
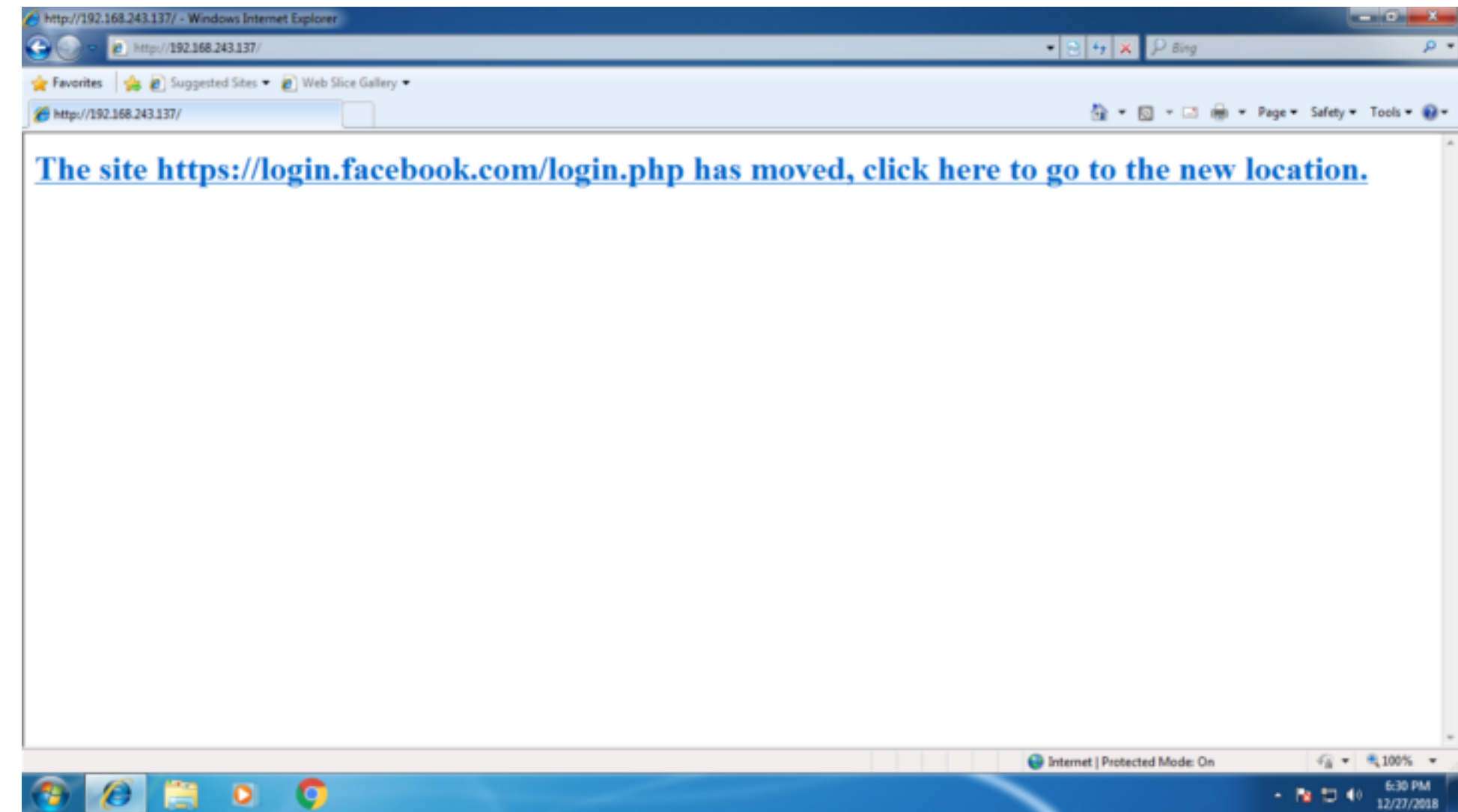
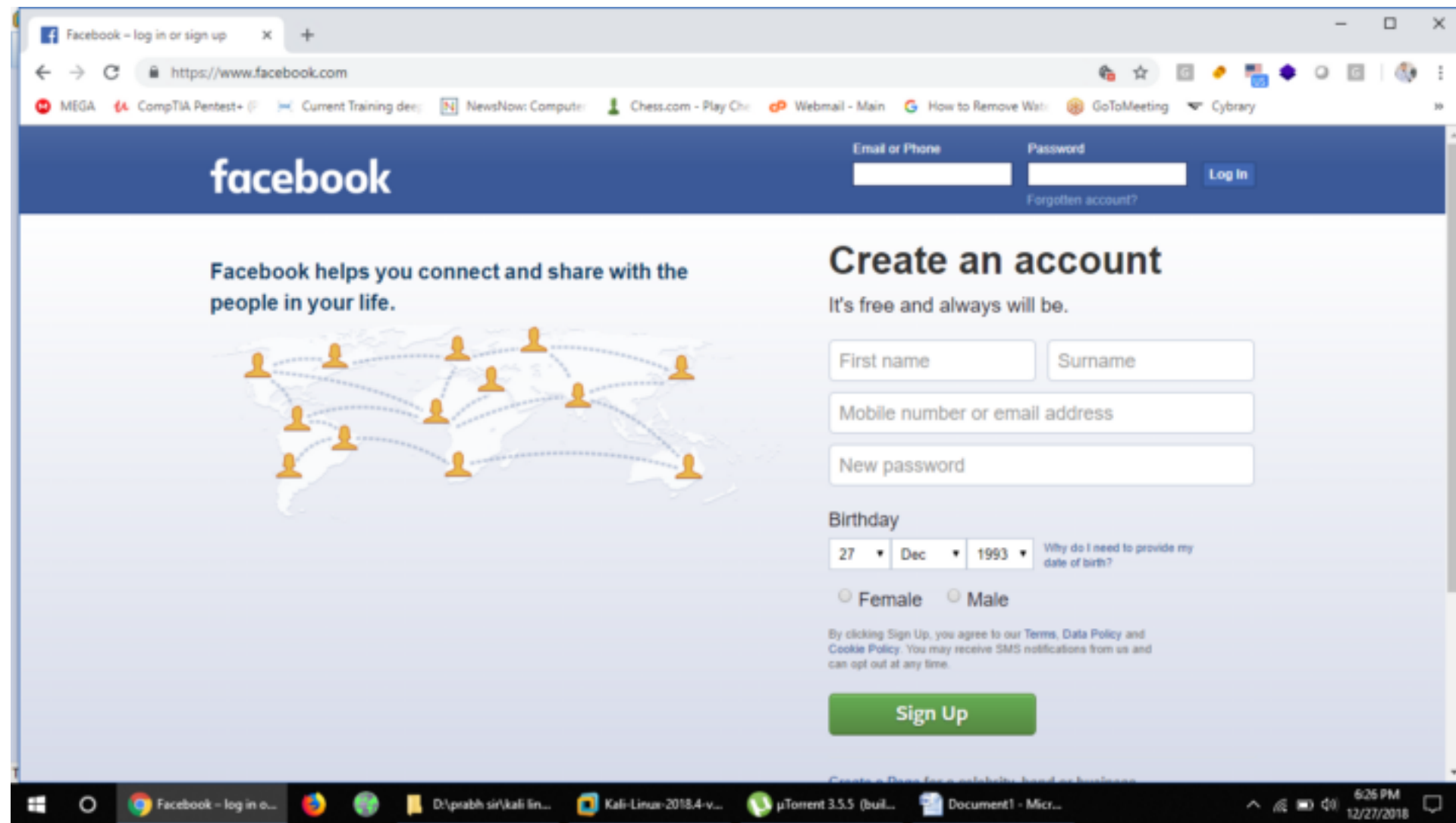
Using subdomains to confuse

<https://paymentorganization.secure.server.com>

Using homographs to confuse

<https://www.paypal.com>

Cloned websites



Drive-by Downloads

User visits a malicious website and clicks on a link or even dialog box!

Auto-loading of attachments in email clients

...

Phishing

Lab 1

1. Start up Social Engineering Toolkit in Kali
2. Create a weaponised spear phishing email and send it to your example email address using the lab mail server. Please do not click on the weaponised file when it arrives!

Phishing

Lab 2

1. Start up Social Engineering Toolkit in Kali (if not already running)
2. Using the Web Jacking attack method create a website clone.
3. Observe the behaviour of the clone.

Phishing

Lab 3

1. Start up Social Engineering Toolkit in Kali (if not already running)
2. Create a malicious QR code directing users to the Juice Shop on your localhost.

Phishing - Mitigations



Clickjacking

Attackers manipulate the visual appearance of a website to trick users into clicking on a fake link, button, or image.

Also known as a *User Interface Redress* attack and belongs to the class of *Confused Deputy Attacks*.

Uses transparent or opaque layers over original websites.

Victims believe they have clicked on the overlay element but the original website element is clicked on.

The attack website uses an iFrame to load the target website and can make use of the absolute positioning features of iFrames for correct visual alignment.

Hard for victims to detect the attack elements over the original website.

Clickjacking

Particularly dangerous when victims have already logged in to an online account

An attacker can trick the victim into performing actions on a trusted site when the victim is already logged in

Attackers used invisible iFrames to trick their victims into changing the plugin's security settings gaining access the microphone and camera of their victims' machines.

CNET

Your guide to a better future

News > Privacy

Adobe addresses Flash Player 'clickjacking' flaw

Flash Player 10 update addresses flaws enabling attackers to fool users into visiting malicious Web sites. It also helps prevent attacks on Webcams and microphones.

Tom Espiner

Oct. 16, 2008 12:02 p.m. PT



Adobe Systems has addressed a security flaw in its Flash Player products that could lead to 'clickjacking' attacks.

Flash Player 10, released on Wednesday, includes a fix for the clickjacking vulnerability published by researchers Jeremiah Grossman and Robert Hansen earlier this month.



Clickjacking attacks take advantage of vulnerabilities in Adobe Flash Player 9.0.124.0 and earlier, as well as vulnerabilities in browsers such as Internet Explorer, Opera, Firefox, and Safari. Exploitation of the flaws could allow an attacker to disguise Web site elements, such as dialog boxes and links, so that the user is fooled into visiting malicious Web sites.

... ..

Clickjacking - Mitigations

Detection and prevention is non-trivial

Not a programming mistake but conceptual issue with JavaScript!

Client side

- Disable JavaScript and iFrames but this would break many legitimate websites
- Browser plugins such as NoScript allow controlled execution of JavaScript scripts on behalf of the user.
- Log out of online accounts when leaving a website, although this could be impractical.

Server side

- Make sure that a website is not frame-able, i. e. a website does not load if it is inside an iFrame. The X-FRAME-OPTIONS header can be set to DENY.
- Websites can include JavaScript code to detect whether a website has been put into an iFrame and break out of the iFrame (***FrameBusting***).

Client Side Storage

Historically just cookies

With HTML5, more powerful alternatives exist

WebStorage: cookie like. Stores key-value pairs.

IndexedDB: Database akin to noSQL databases. Stores files or BLOBs (Binary Large Objects)

What is the problem?

Client Side Storage - Mitigations

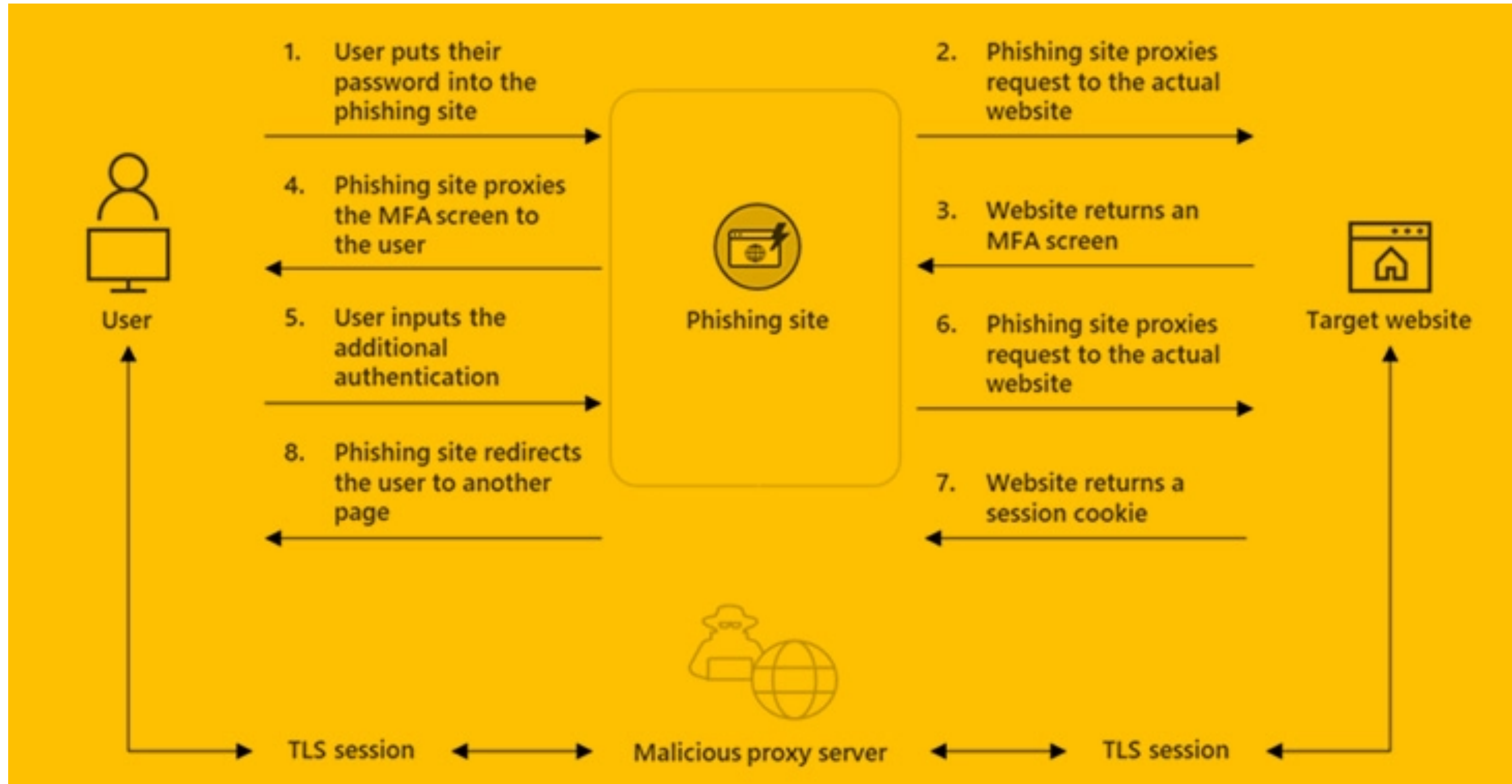
Cryptographically sign sensitive data stored on client side

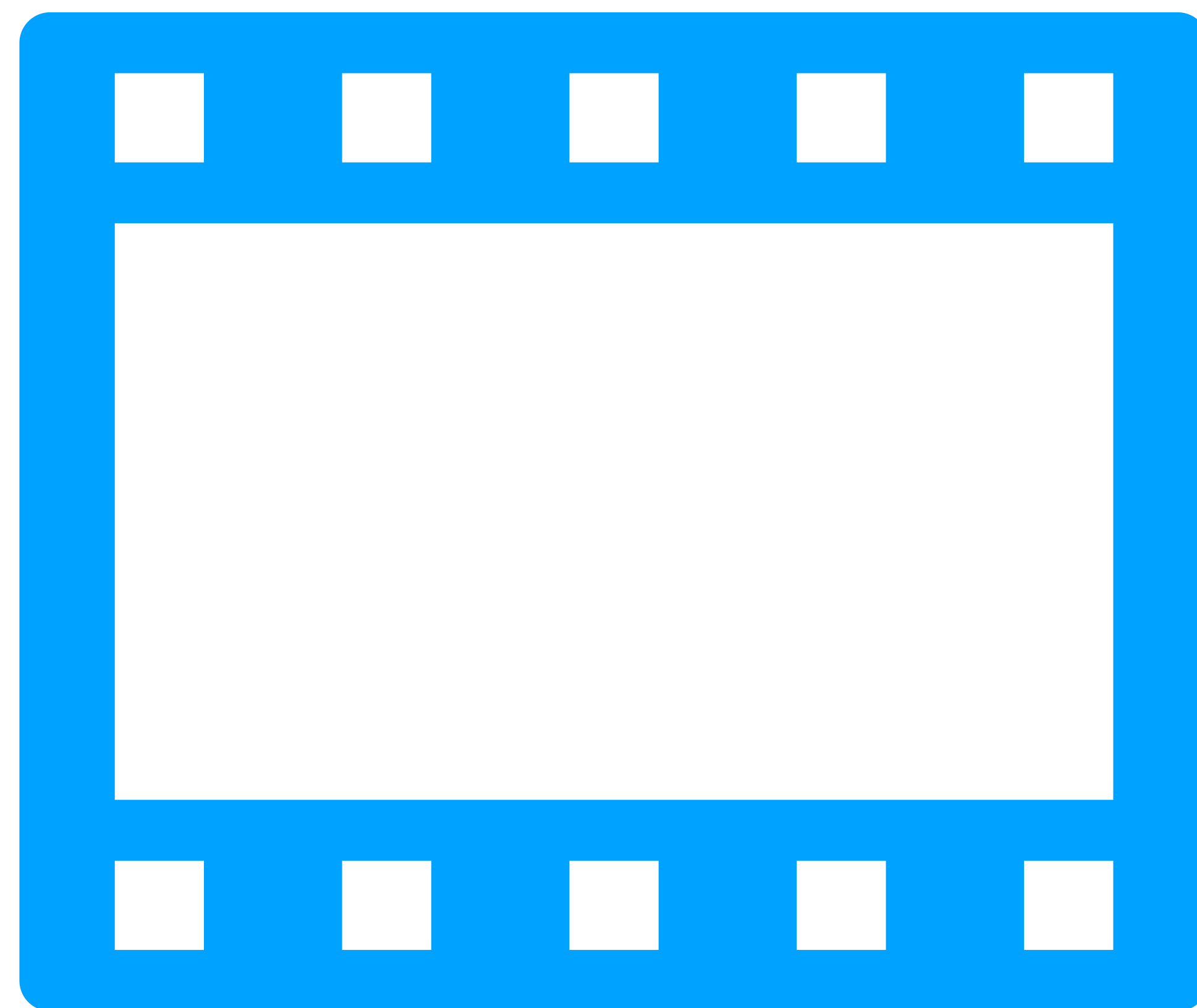
Verify it upon retrieval

Stored information isn't automatically cleared after a user leaves a website

Use relevant API features to do so if needed

Phishing-as-a-Service





Further Reading

CyBOK - Web and Mobile Security Knowledge Area (on which this lecture is based): https://www.cybok.org/media/downloads/Web_Mobile_Security_v1.0.1.pdf

More Hands-on Learning

Social Engineering Toolkit within Kali (remember the discussion we had on ethics and legality on Day 1!)